

# ETSI CRA Consumer IoT Vertical Standards

Deep Dive Session,  
6<sup>th</sup> of February 2026

Essential cybersecurity requirements for

- **smart home general purpose virtual assistants**  
[https://docbox.etsi.org/cyber/EUSR/Open/EN\\_304-631\\_V0.2.1\\_2026-02-05\\_Smart-home-virtual-assistants\\_Mature-draft.pdf](https://docbox.etsi.org/cyber/EUSR/Open/EN_304-631_V0.2.1_2026-02-05_Smart-home-virtual-assistants_Mature-draft.pdf)
- **smart home products with security functionalities**  
[https://docbox.etsi.org/cyber/EUSR/Open/EN\\_304-632\\_V0.2.1\\_2026-02-05\\_Smart-home-security\\_Mature-draft.pdf](https://docbox.etsi.org/cyber/EUSR/Open/EN_304-632_V0.2.1_2026-02-05_Smart-home-security_Mature-draft.pdf)
- **internet connected toys**  
[https://docbox.etsi.org/cyber/EUSR/Open/EN-304-633\\_V0.2.3\\_2026-02-05\\_Connected-toys\\_Mature-Draft.pdf](https://docbox.etsi.org/cyber/EUSR/Open/EN-304-633_V0.2.3_2026-02-05_Connected-toys_Mature-Draft.pdf)
- **personal wearable products**  
[https://docbox.etsi.org/cyber/EUSR/Open/EN\\_304-634\\_V0.2.3\\_2026-02-05\\_Personal-wearables\\_Interim-draft.pdf](https://docbox.etsi.org/cyber/EUSR/Open/EN_304-634_V0.2.3_2026-02-05_Personal-wearables_Interim-draft.pdf)



# Content

- **ETSI CRA Consumer IoT (CIoT) Verticals' methodology**
- **Smart Home General Purpose Assistants**
- **Smart Home Products with Security Functionalities**
- **Internet Connected Toys**
- **Personal Wearable Products**

# ETSI CRA CIoT Verticals' methodology







# Methodology – Cyber Resilience Act (CRA) Context I

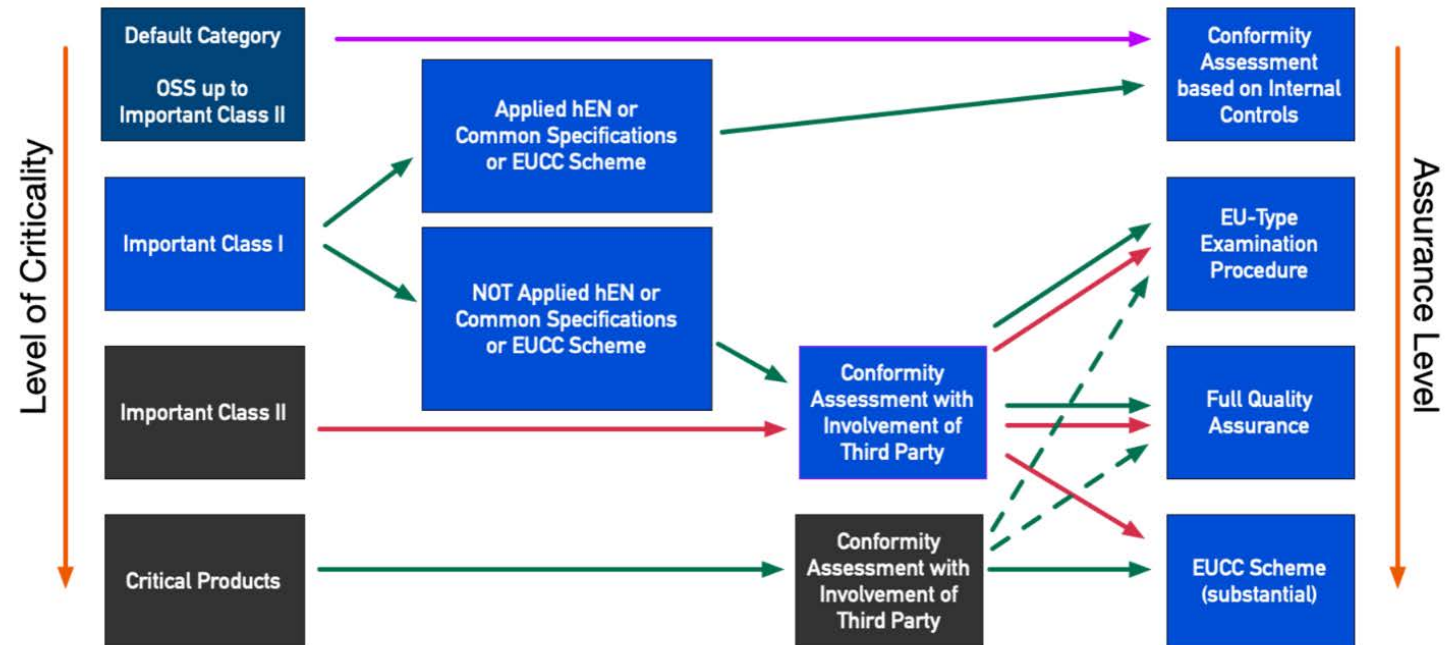
## Legal framework

- CRA Regulation (EU) 2024/2847 ANNEX III categorizes the CIoT products addressed by the ETSI CRA CIoT verticals as “Class I Important Products”
- Implementing Regulation (EU) 2025/2392 “Technical description of the categories of important and critical products” provides a more detailed technical description of the Class I Important CIoT Products
- Standardisation Request M/606 by European Commission provides the mandate for ETSI CRA CIoT verticals that aim for citation the Official Journal of the European Union (OJEU) for presumption of conformity
- Conformity of a Class I important product with digital elements to a harmonized European standard (hEN) cited in the OJEU for presumption of conformity enables a Module A (internal production control) CRA conformity assessment for the respective essential cybersecurity requirements (ECR), that does not require the involvement of a third party



# Methodology – Cyber Resilience Act (CRA) Context II

## CRA Conformity Assessment



by Jose Emilio Rico, DEKRA (with modifications)

# Methodology – ETSI CRA ClOT Verticals Structure

## Main clauses (currently in the documents)

- Clause 1: Scope
- Clause 2: References
- Clause 3: Definitions
- Clause 4: Product Context
- Clause 5: Requirements specifications
- Clause 6: Assessing for compliance with requirements

## Annexes (currently in the documents)

- ANNEX A (informative): Mapping of standard's requirements to ECR
- ANNEX B (informative): Guidance of the application of the standard
- ANNEX C (informative): Standard's methodology for the assessment of cybersecurity risks
- ANNEX D (normative): Assignment of impact classes to assets
- ANNEX E (normative): Protection measures and related assessments
- ANNEX F (informative): Mapping of standard's requirements to (not-)covered risks
- ANNEX G (informative, in preparation): Relation to ETSI EN 303 645 and ETSI TS 103 701



# Methodology – Clause 1 (Scope), Clause 2 (References)

The ETSI CRA ClIoT verticals' scope is determined by:

- the corresponding descriptions provided in Implementing Regulation (EU) 2025/2392 “Technical description of the categories of important and critical products” ; and
- The descriptions provided in the standard's clause 4 (Product Context)

The ETSI CRA ClIoT verticals plan normative references to:

- CEN/CLC JT013090:2026 (CEN/CLC prEN 40000-1-3): “Cybersecurity requirements for products with digital elements - Vulnerability Handling”; and
- Agreed Cryptographic Mechanisms: “European Union Agency for Cybersecurity, European Cybersecurity Certification Group - Sub-group on Cryptography - Agreed Cryptographic Mechanisms.”





# Methodology – Clause 3 (Definitions)

Inherit definitions from:

- CRA
- CEN/CLC JT013095:2026 (CEN/CLC prEN 40000-1-1): “Cybersecurity requirements for products with digital elements – Vocabulary”

Provide definitions based on e.g. ETSI EN 303 645, CEN/CLC EN18031-series on:

- Generic model parameter such as
  - Architectural components
  - Asset categories
  - Operational environments – physical (POE) and logical
  - Interfaces
  - Users
- Specific data and function assets





# Methodology – Clause 4 (Product Context)

The Product context describes the relevant technical details and models that form the standard's scope and are used to formulate the requirements, as:

- Functions provided by the product and data processed by the product
- Product architecture and architectural components of the product
- Operational environment (both logical and physical) of the product
- Interfaces provided by the product
- Distribution of security functions (esp. relevant for software)
- Using entities of the product
- Information on use cases and corresponding security profiles

# Methodology – Clause 5 (Requirements) I

## Requirement's scope

- Clause 5.1 (Product's technical requirements specifications): Requirements address “properties of products with digital elements”
- Clause 5.2 (Requirements specifications for vulnerability handling activities related to the product): Requirements address “activities/processes related to (vulnerability handling of) the product”

| Clause | heading                                      | Clause | heading                                               |
|--------|----------------------------------------------|--------|-------------------------------------------------------|
| 5.1.1  | Known exploitable vulnerabilities            | 5.1.7  | Availability protection                               |
| 5.1.2  | Default configuration                        | 5.1.8  | Impact minimization                                   |
| 5.1.3  | Authentication and access control mechanisms | 5.1.9  | Limit attack surface                                  |
| 5.1.4  | Integrity protection                         | 5.1.10 | Logging and monitoring mechanisms                     |
| 5.1.5  | Confidentiality protection                   | 5.1.11 | Deletion mechanisms                                   |
| 5.1.6  | Data minimization                            | 5.1.12 | Other product's technical requirements specifications |



# Methodology – Clause 5 (Requirements) II

## Requirement's structure

- „Atomic“ requirement:  
  
„The product shall support the automated update of its software.“
- „Conditional“ requirement:  
  
„Where at least one function, whose use can cause harm with IMP.FH.High is provided by the product and the product includes a hardware MP, the hardware MP shall use a bootloader function that only executes core software at startup, whose integrity and authenticity is verified.“
- Requirement with assignment table for protection measures' strength:  
  
„The product shall use confidentiality protecting communication mechanisms to protect the confidentiality of communicated confidential data, where the corresponding confidentiality protection measures strengths are specified in section E.5.1 and the minimal required confidentiality protection measures' strength are determined by table 7.“





# Methodology – Clause 5 (Requirements) III

Requirement with assignment table for protection measures strength:

- „The product shall use confidentiality protecting communication mechanisms to protect the confidentiality of communicated confidential data, [where the corresponding confidentiality protection measures strengths are specified in section E.5.1](#) and the minimal required confidentiality protection measures’ strength are determined by table 7.“

Table 7: Assignment of protection mechanisms strength level for the confidentiality of communicated data.

|                                                                                                |                                             |                         | confidential data impact class |                   |                   |
|------------------------------------------------------------------------------------------------|---------------------------------------------|-------------------------|--------------------------------|-------------------|-------------------|
|                                                                                                |                                             |                         | IMP.CONF.Low                   | IMP.CONF.Medium   | IMP.CONF.High     |
| Attack Surface determined by COM, IF and POE of RDPS or MP that communicates confidential data | COM.Local via IF.Machine or IF.HumanLogical | POE.FullyControlled     | N/A                            | N/A               | CONF.COM.Normal   |
|                                                                                                |                                             | POE.PartiallyControlled | N/A                            | CONF.COM.Basic    | CONF.COM.Normal   |
|                                                                                                |                                             | POE.Uncontrolled        | CONF.COM.Basic                 | CONF.COM.Normal   | CONF.COM.Enhanced |
|                                                                                                | COM.Adjacent via IF.Any                     | POE.Any                 | CONF.COM.Enhanced              | CONF.COM.Enhanced | CONF.COM.Enhanced |
|                                                                                                | COM.Public via IF.Any                       |                         | CONF.COM.Enhanced              | CONF.COM.Enhanced | CONF.COM.Enhanced |

## E.5.1 CONF-COM Communication of confidential data

### E.5.1.1 General

The present document specifies the strength of mechanisms to protect the confidentiality of communicated confidential data by their resistance against certain attack types. Those attack types are constructed such that mechanisms of higher strength protect against all attack types required for lower strengths.

### E.5.1.2 communication of confidential data protection strength level basic

The communication of confidential data protection strength level basic shall protect against the following attack types:

**eavesdropping:** An attacker secretly intercepts the communication between the SHGPVA and another entity or another part of the SHGPVA.

### E.5.1.3 communication of confidential data protection strength level normal

The communication of confidential data protection strength level normal shall protect against the following attack types:

**eavesdropping:** An attacker secretly intercepts the communication between the SHGPVA and another entity or another part of the SHGPVA.

**direct identity spoofing attack:** An attacker mimics another entity to gain a trust relationship with the SHGPVA

**downgrade of communication protocols attack:** An attacker forces to use of a legacy, less secure, communication protocol



# Methodology – Clause 6 (Assessments) I

General structure for assessments:

- Assessment objective
- Assessment preparation
- Assessment activities
- Assignment of verdict
- Supporting Evidence

Assessments are divided into three categories that can be combined:

- Conceptual assessment regarding:  
Indication for (non-) compliance in documentation
- Functional assessment concerning
  - completeness of documentation  
Indications for correctness/completeness of documentation
  - sufficiency of implemented measures  
Indications for correct implementation of security measures

# Methodology – Clause 6 (Assessments) II

Example based on [AUM-FH] in ETSI CRA Clot Draft on smart home general purpose virtual assistants, see:

- Clause 5.1.3.2 [AUM-FH] (requirement on authentication)
- ANNEX E 3.1 on authentication strength level (defined based on resistance against certain attack types)
- Clause 6.1.4.2 [AUM-FH] (assessment on authentication)
- ANNEX E 3.2 on the (functional sufficiency) assessments for authentication strength level



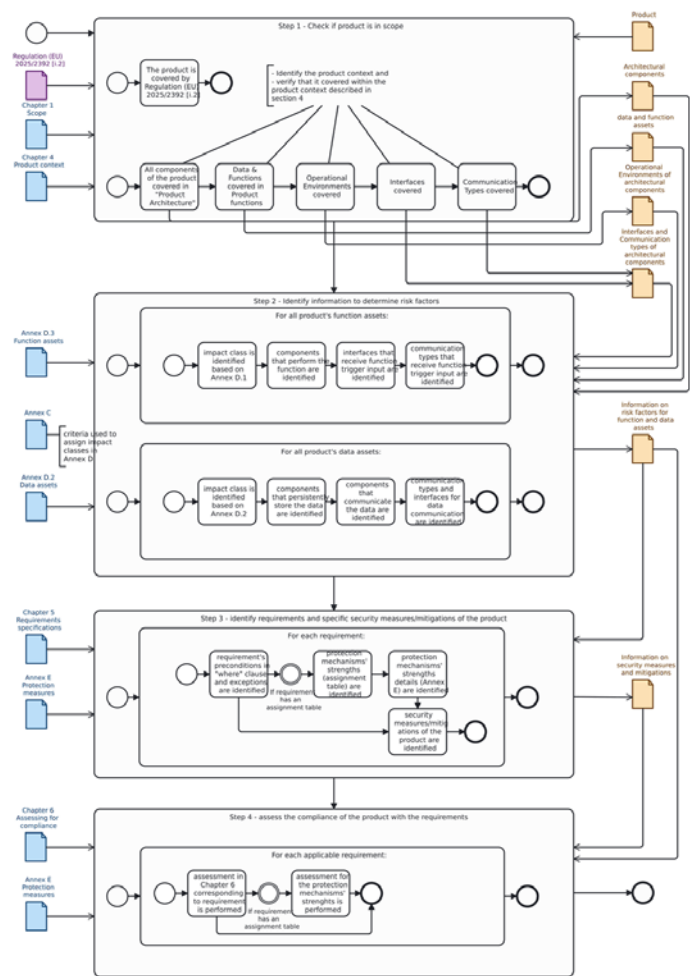
# Methodology – ANNEX A (Mapping to ECRs, informative)

Disclaimer: **DRAFT ANNEX A - DO NOT CONSIDER THE CONTENT - See identified gaps in Annex F**

| Harmonised Standard ETSI EN 304 631 |                                                                                                                                                                                                           |                            |                                                                                                                                                                                                                                                                                                                                                                                               |                            |           |
|-------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------|-----------|
| Requirement                         |                                                                                                                                                                                                           |                            |                                                                                                                                                                                                                                                                                                                                                                                               | Requirement Conditionality |           |
| No                                  | Description                                                                                                                                                                                               | Requirements of Regulation | Clause(s) of the present document                                                                                                                                                                                                                                                                                                                                                             | U/C                        | Condition |
| <b>9</b>                            | Products with digital elements protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks. | Annex I, Part I, (2)(h)    | [ [AVAI-TIME-RECO-POW] <a href="#">5.1.7.1</a><br>[AVAI-TIME-NETW] <a href="#">5.1.7.2</a><br>[AVAI-TIME-RECO-NETW] <a href="#">5.1.7.3</a><br>[AVAI-TIME-OUTA-NOT] <a href="#">5.1.7.4</a><br>[AVAI-TIME-PREV-NOT] <a href="#">5.1.7.5</a><br>[AVAI-TIME-NET-PRIO] <a href="#">5.1.7.6</a><br>[AVAI-TIME-RES-PRIO] <a href="#">5.1.7.7</a><br>[AVAI-TIME-DOS-RATE] <a href="#">5.1.7.9</a> ] | U                          |           |
| <b>10</b>                           | Products with digital elements minimize the negative impact by the products themselves or connected products on the availability of services provided by other products or networks.                      | Annex I, Part I, (2)(i)    | [ [AVAI-TIME-IMP-AMP] <a href="#">5.1.7.8</a> ]                                                                                                                                                                                                                                                                                                                                               | U                          |           |
| <b>11</b>                           | Products with digital elements are designed, developed and produced to limit attack surfaces, including external interfaces.                                                                              | Annex I, Part I, (2)(j)    | [ [LAS-INVAL] <a href="#">5.1.9.1</a><br>[LAS-INSAN] <a href="#">5.1.9.2</a><br>[LAS-PHY-INF] <a href="#">5.1.9.3</a><br>[LAS-LOGIC-INF] <a href="#">5.1.9.4</a><br>[LAS-APP] <a href="#">5.1.9.5</a><br>[LAS-SBOOT] <a href="#">5.1.9.6</a> ]                                                                                                                                                | U                          |           |



# Methodology – ANNEX B (Guidance, informative)



# Methodology – ANNEX C (Standard's risk assessment, informative)

## Current content:

- ANNEX C.1 “Guidance for determining impact classes”

### C.1 Guidance for determining impact classes

#### C.1.1 General

The present document uses the following criteria to determine the impact classes of different specific SHGPVA assets provided in annex [D](#).

#### C.1.2 confidential data

##### confidentiality impact class low (IMP.CONF.Low):

The disclosure may lead to:

- inconvenient consequences on the consumer(s); or
- additional or increased attack opportunities over a short time and limited to communication types not higher than local on the SHGPVA.

##### confidentiality impact class medium (IMP.CONF.Medium):

The disclosure may lead to:

- serious impact on the consumer(s);
- additional or increased attack opportunities over a short time on the SHGPVA or a limited number of other products; or
- additional or increased attack opportunities over a prolonged time limited to non-key-functionalities on the SHGPVA.

## Not addressed content:

- E.g. guidance on impact class assignment for functions whose use can cause harm
- Methodology on processing other risk relevant parameter (here primary likelihood/attack surface parameters) such as:
  - Physical operational environments
  - Interfaces and communication types



# Methodology – ANNEX D (Impact Classes, normative)

## Normative assignment of impact classes to data/function assets

- Central part for the application of the standards' current methodology
- Necessary for determining the applicability of some requirements
- Necessary to identify the minimal required protection mechanisms' strength

# Methodology – ANNEX E (Protection Measures, normative)

ANNEX E defines

- Protection mechanisms' strength levels based on e.g.
  - Resistance against certain attack types (e.g. for authentication, secure communication)
  - Security measures (e.g. secure storage, integrity/authenticity verification of software packages)
- Functional sufficiency assessments for protection mechanisms' strength levels





# Methodology – ANNEX F (covered/not covered risks, informative)

- Mapping of the existing requirements to identified threat scenarios
- Presentation of threat scenarios where no detailed mitigation is provided
- Presentation of relevant attack surface parameter for threat scenarios
- Clear relation to (residual) risks is still missing

| No. | Threat Actor   | Threat action | Asset                               | Threat details                         |                         | Requirement(s) for mitigation                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | Relevant attack surface parameter | Risk coverage |
|-----|----------------|---------------|-------------------------------------|----------------------------------------|-------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------|---------------|
| [1] | A threat actor | (mis)uses     | a function whose use can cause harm | on the SHGPVA                          |                         | <b>Prevention:</b><br>[ACM-FH] <a href="#">5.1.3.1</a><br>[AUM-FH] <a href="#">5.1.3.2</a><br>[AUTHZ-LP] <a href="#">5.1.3.3</a><br>[AUTHZ-R] <a href="#">5.1.3.4</a><br>[AVAI-TIME-IMP-AMP] <a href="#">5.1.7.8</a><br>[LAS-PHY-INF] <a href="#">5.1.9.3</a><br>[LAS-LOGIC-INF] <a href="#">5.1.9.4</a><br>[LAS-APP] <a href="#">5.1.9.5</a><br>[SDC-AUM-FH] <a href="#">5.1.2.1</a><br><b>Information:</b><br>[LOG-LOW] <a href="#">5.1.10.1</a><br>[LOG-MEDIUM] <a href="#">5.1.10.2</a><br>[LOG-HIGH] <a href="#">5.1.10.3</a><br>[LOG-TIME] <a href="#">5.1.10.4</a><br>[LOG-TIME-HIGH] <a href="#">5.1.10.5</a><br>[LOG-STORAGE] <a href="#">5.1.10.6</a><br>[LOG-BACKUP] <a href="#">5.1.10.7</a><br>[USERNOT-NOSECFUC] <a href="#">5.1.12.1</a><br><b>Restoration:</b><br>[SDC-FRM] <a href="#">5.1.2.4</a> | COM, IF and POE                   | C             |
| [2] |                | tamper        | integrity relevant data             | permanently stored on the SHGPVA       |                         |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |                                   | N             |
| [3] |                |               |                                     | volatile stored on the SHGPVA          |                         |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |                                   | N             |
| [4] |                |               |                                     | communicated from or to the MP or RDPS |                         | <b>Prevention:</b><br>[INT-COM] <a href="#">5.1.4.2</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             | COM, IF and POE                   | C             |
| [5] |                | discloses     | confidential data                   | on the SHGPVA                          | unnecessarily processed | <b>Prevention:</b><br>[DMIN-DJST] <a href="#">5.1.6.1</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |                                   | C             |
| [6] |                |               |                                     | permanently stored on the SHGPVA       | during storage          | <b>Prevention:</b><br>[CONF-SSM] <a href="#">5.1.5.1</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            | POE                               | C             |



# Methodology – ANNEX G (relation to EN 303 645, informative)

Intend to be filled with information on the relation between the ETSI CRA CIoT Standards and the ETSI EN 303 645 eco system, once public stakeholder consultation and HASC assessment resulted in more mature content

ETSI EN 303 645 V3.1.3 (2024-09)



**CYBER;**  
Cyber Security for Consumer Internet of Things:  
Baseline Requirements

ETSI TS 103 701 V2.1.1 (2025-05)



**Cyber Security (CYBER);**  
Cyber Security for Consumer Internet of Things:  
Conformance Assessment of Baseline Requirements

## Hot Topics of Current Discussions:

- Complete requirements and assessment criteria
- Incorporation of more detailed use case profiles
- Refinement of models for
  - data and function assets
  - architectural components
- Refinement of the methodology for the assignment of impact classes
- Changes in the requirement's assignment tables
- Cross vertical alignment

# Q&A





# Smart Home General Purpose Virtual Assistants



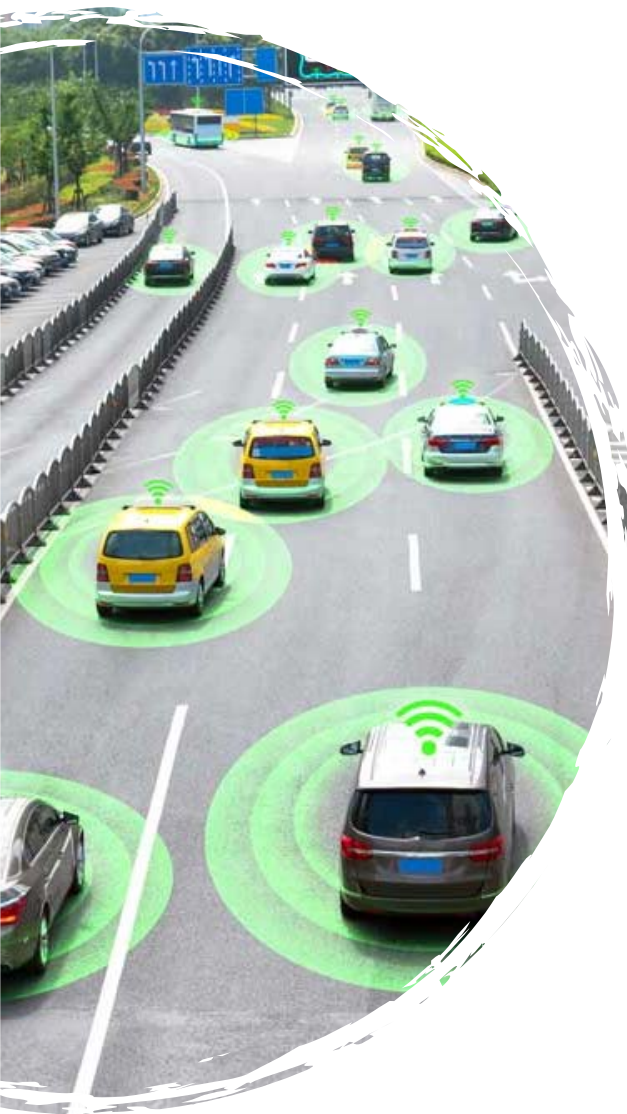
# Smart Home General Purpose Assistants – Clause 1 (Scope)

## Technical Description Implementing Regulation (EU) 2025/2392 Annex I #16

- Smart home general purpose virtual assistants - “Products with digital elements that communicate on the public Internet, whether directly or via other equipment, that process demands, tasks or questions based on natural language prompts, such as through audio or written input, and that, based on those demands, tasks or questions, provide access to other services or control the functions of connected devices in residential settings.”
- “This category includes but is not limited to smart speakers with an integrated virtual assistant, and standalone virtual assistants that meet this description.”

## Considerations

- Technical description seems to include software-only products
- Overlaps concerning functionality between smart home general purpose virtual assistants (falling under #16) and smart home products with security functionalities (falling under #17)



# Smart Home General Purpose Assistants – Clause 4 (Product Context)

Defined term (Clause 3) in the standard:

- virtual assistant function: [...] function which provides function output as reaction to function trigger input related to assistance of a consumer and can process natural language prompts

Product functions (Clause 4) in the standard:

The present document addresses the following essential functionalities of the product:

- virtual assistant functions that might make use of the following functions:
  - audio input/output functions
  - video input/output functions
  - [...] functions which can communicate/modify [...] data

The essential and supporting functionalities might process the following data assets:

- public data asset, personal notes/calendar/contact data, health data, activity data, device location data
- ...



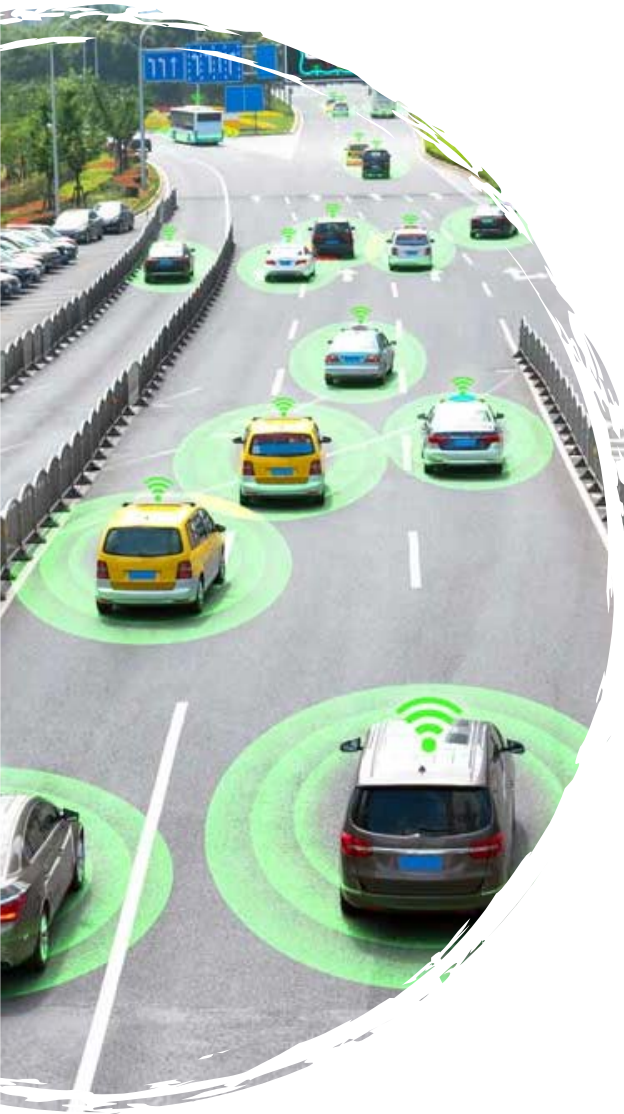


# Smart Home General Purpose Assistants – ANNEX D (Impact Classes)

## D.2 Data assets

Table D.1: Mapping of specific data assets to impact classes for generic data asset categories

| specific data asset           | impact class for data asset categories    |                                                 |                                                                  |                                                                  |
|-------------------------------|-------------------------------------------|-------------------------------------------------|------------------------------------------------------------------|------------------------------------------------------------------|
|                               | impact class for confidential SHGPVA data | impact class for integrity relevant SHGPVA data | impact class for time critical availability relevant SHGPVA data | impact class for loss critical availability relevant SHGPVA data |
| <u>public data asset</u>      | IMP.CONF.Low                              | IMP.INT.Medium                                  | IMP.AVAI.TIME.Low                                                | no                                                               |
| <u>personal calendar data</u> | IMP.CONF.Medium                           | IMP.INT.Medium                                  | IMP.AVAI.TIME.Low                                                | IMP.AVAI.LOSS.Medium                                             |
| <u>personal notes data</u>    | IMP.CONF.Medium                           | IMP.INT.Medium                                  | IMP.AVAI.TIME.Low                                                | IMP.AVAI.LOSS.Medium                                             |
| <u>personal contact data</u>  | IMP.CONF.Medium                           | IMP.INT.Medium                                  | IMP.AVAI.TIME.Low                                                | IMP.AVAI.LOSS.Medium                                             |
| <u>health data</u>            | IMP.CONF.High                             | IMP.INT.High                                    | IMP.AVAI.TIME.Low                                                | IMP.AVAI.LOSS.Medium                                             |
| <u>activity data</u>          | IMP.CONF.Medium                           | IMP.INT.Medium                                  | IMP.AVAI.TIME.Low                                                | IMP.AVAI.LOSS.Medium                                             |





# Smart Home General Purpose Assistants – Open issues

Vertical specific open issues:

- Define data and function assets related to the control of other devices and services in accordance with the approach for Smart Home Products with Security Functionalities.
- Consider more detailed requirements on voice recording/transmission behavior and/or mandatory configuration options for the user on this topic (cf. Provisions SVD 8-X in ETSI TS 103 927 on “Cyber Security for Consumer Internet of Things; Requirements for Smart Voice-controlled Device”)



# Q&A



# Smart Home Products with Security Functionalities



# Smart Home Products with Security Functionalities – Clause 1 (Scope)

Co-funded by



Co-funded by  
the European Union



## Technical Description Implementing Regulation (EU) 2025/2392 Annex I #17

- Smart home products with security functionalities, including smart door locks, security cameras, baby monitoring systems and alarm systems:
  - “Products with digital elements that protect the physical security of consumers in a residential setting and which can be controlled or managed remotely from other systems, as well as hardware and software that centrally control such products.”
  - “This category includes but is not limited to smart door locking devices, baby monitoring systems, alarm systems and home security cameras.”

## Considerations

- Technical description seems to include software-only products
- Overlaps concerning functionality between smart home products with security functionalities (falling under #17) and smart home general purpose virtual assistants (falling under #16)



# Smart Home Products with Security Functionalities – Clause 4 (Product Context)

Co-funded by



Co-funded by  
the European Union



Defined term (Clause 3) in the standard:

- residential physical security function: function which provides function output as reaction to function trigger input related to residential physical security

Product functions (Clause 4) in the standard:

The present document addresses the following essential functionalities of products:

- residential physical security functions that might make use of the following functions:
  - Audio/Video input/output functions
  - [...] functions which can communicate/modify [...] data
  - cyber physical control/alarm/lock function

The essential and supporting functionalities might process the following data assets:

- Audio/video input data,
- bolt position/alarm/lock control data
- ...

# Smart Home Products with Security Functionalities – ANNEX D (Impact Classes)

Co-funded by



Co-funded by  
the European Union



Table D.2: Mapping of specific function assets to impact classes for generic function asset categories

| specific function asset               | impact class for function asset categories   |                                                                                  |                                                                 |
|---------------------------------------|----------------------------------------------|----------------------------------------------------------------------------------|-----------------------------------------------------------------|
|                                       | impact class for integrity relevant function | impact class for time sensitive function                                         | impact class for function, whose use can cause harm             |
| SHPSF lock function                   | IMP.INT.Medium                               | IMP.AVAI.TIME.Medium                                                             | IMP.FH.High                                                     |
| SHPSF cyber physical alarm function   | IMP.INT.High                                 | IMP.AVAI.TIME.High                                                               | IMP.FH.Medium                                                   |
| positioning function                  | IMP.INT.Medium                               | IMP.AVAI.TIME.Medium                                                             | no                                                              |
| SHPSF cyber physical control function | IMP.INT.High                                 | IMP.AVAI.TIME =<br>IMP.AVAI.TIME of the<br>controlled cyber physical<br>function | IMP.FH = IMP.FH of the<br>controlled cyber physical<br>function |
| SHPSF surrounding monitoring function | IMP.INT.Medium                               | IMP.AVAI.TIME.High                                                               | IMP.FH.Medium                                                   |
| SHPSF lock function with failsafe     | IMP.INT.Medium                               | IMP.AVAI.TIME.Low                                                                | IMP.FH.High                                                     |

# Smart Home Products with Security Functionalities – Open issues

Co-funded by



Co-funded by  
the European Union



Vertical specific open issues:

- Add/refine further sensor/actuator functionalities specifically in alignment with CENELEC TC79 “Alarm systems”

# Q&A





# Internet Connected Toys

---



# Internet Connected Toys – Clause 1 (Scope)

## Technical Description Implementing Regulation (EU) 2025/2392 Annex I #18

- Internet connected toys:
  - “Internet connected toys that have social interactive features are products with digital elements that are covered by Directive 2009/48/EC, that communicate on the public Internet, whether directly or via any other equipment, and that have embedded technologies that enable inbound and outbound communication, such as keyboard, microphone, speaker or camera.”
  - “Internet connected toys that have location tracking features are products with digital elements that are covered by Directive 2009/48/EC, that communicate on the public Internet, whether directly or via any other equipment, and that have technologies that enable tracking or inferring of the geographical location of the toy or its user. Where the toy merely detects the proximity of the user or of other toys by using sensing technologies, the toy is not to be considered to have location tracking features.”

### Considerations:

- Overlaps concerning functionality and parental control between internet connected toys (falling under #18) and personal wearable products that are intended for the use by and for children (falling under #19)



# Internet Connected Toys – Clause 4 (Product Context)

Defined term (Clause 3) in the standard:

- social interactive function: [...] function which provides function output as reaction to function trigger input related to social interactions
- child: human entity under 14 years of age
- guardian: natural or legal entity with responsibility for the child

Product functions (Clause 4) in the standard:

The present document addresses the following essential functionalities of products:

- social interactive functions that might make use of the following functions:
  - Audio/Video input/output functions
  - [...] functions which can communicate/modify [...] data
- Positioning/location sharing/emergency location/geo fencing notification functions
- parental control functions

The essential and supporting functionalities might process the following data assets:

- Audio/video input data,
- Main product (MP) position/emergency location sharing/geofence location data
- social interactive data
- ...



# Internet Connected Toys (ICT) – Clause 5 (Requirements)

## 5.1.3.2 [PARCONT] Support of parental control

The ICT shall support parental control functions, covering the parents' or guardians' control of:

- access rights on the ICT of children,
- (if the ICT allows children to access external content), the sources where children are allowed to access external content from and
- (if the ICT allows children to communicate with other persons), the persons that are allowed to communicate with children.

## 5.1.2.5 [SDC-PARCONT] Default configuration for parental control

The ICT shall by default be configured to:

- deny children access to security relevant configuration function,
- restrict the sources where children can access external content from to trusted sources, and
- restrict entities that can communicate with the child to trusted entities

## 5.1.3.6 [AUTHZ-PC] Authorization policies for parental control

The ICT shall use an authorization policy that can differentiate between guardian and child.





# Internet Connected Toys (ICT) – Clause 5 (Requirements)/ANNEX D/ANNEX E

Table 5: Assignment of protection mechanisms strength level for the integrity protection of outgoing data and for the integrity verification of incoming data.

|                                                                                                      |                                             |                         | integrity relevant data impact class |                  |                  |
|------------------------------------------------------------------------------------------------------|---------------------------------------------|-------------------------|--------------------------------------|------------------|------------------|
|                                                                                                      |                                             |                         | IMP.INT.Low                          | IMP.INT.Medium   | IMP.INT.High     |
| Attack Surface determined by COM, IF and POE of RDPS or MP that communicates integrity relevant data | COM.StrictLocal via IF.Machine              | POE.Any                 | INT.COM.Basic                        | INT.COM.Basic    | INT.COM.Basic    |
|                                                                                                      | COM.Local via IF.Machine or IF.HumanLogical | POE.FullyControlled     | INT.COM.Basic                        | INT.COM.Basic    | INT.COM.Normal   |
|                                                                                                      |                                             | POE.PartiallyControlled | INT.COM.Basic                        | INT.COM.Normal   | INT.COM.Enhanced |
|                                                                                                      |                                             | POE.Uncontrolled        | INT.COM.Normal                       | INT.COM.Enhanced | INT.COM.Enhanced |
|                                                                                                      | COM.Adjacent via IF.Any                     | POE.Any                 | INT.COM.Enhanced                     | INT.COM.Enhanced | INT.COM.Enhanced |
|                                                                                                      | COM.Public via IF.Any                       |                         | INT.COM.Enhanced                     | INT.COM.Enhanced | INT.COM.Enhanced |

Table D.1: Mapping of specific data assets to impact classes for generic data asset categories

| specific data asset             | impact class for data asset categories |                                              |                                                               |                                                               |
|---------------------------------|----------------------------------------|----------------------------------------------|---------------------------------------------------------------|---------------------------------------------------------------|
|                                 | impact class for confidential ICT data | impact class for integrity relevant ICT data | impact class for time critical availability relevant ICT data | impact class for loss critical availability relevant ICT data |
| MP position data                | IMP.CONF.Medium                        | IMP.INT.Medium                               | IMP.AVAI.TIME.Medium                                          | IMP.AVAI.LOSS.Low                                             |
| emergency location sharing data | IMP.CONF.Low                           | IMP.INT.Medium                               | IMP.AVAI.TIME.High                                            | IMP.AVAI.LOSS.Low                                             |
| geofence location data          | IMP.CONF.Low                           | IMP.INT.Medium                               | IMP.AVAI.TIME.Medium                                          | IMP.AVAI.LOSS.Low                                             |
| social interactive data         | IMP.CONF.Medium                        | IMP.INT.Medium                               | IMP.AVAI.TIME.Low                                             | IMP.AVAI.LOSS.Medium                                          |
| audio input data                | IMP.CONF.Medium                        | IMP.INT.Medium                               | IMP.AVAI.TIME.Low                                             | no                                                            |
| video input data                | IMP.CONF.Medium                        | IMP.INT.Medium                               | IMP.AVAI.TIME.Low                                             | no                                                            |
| network status data             | IMP.CONF.Medium                        | IMP.INT.Medium                               | IMP.AVAI.TIME.Medium                                          | IMP.AVAI.LOSS.Low                                             |
| authorization policy data       | IMP.CONF.Medium                        | IMP.INT.High                                 | IMP.AVAI.TIME.Medium                                          | IMP.AVAI.LOSS.Low                                             |
| ICT state data                  | IMP.CONF.Medium                        | IMP.INT.Medium                               | IMP.AVAI.TIME.Medium                                          | IMP.AVAI.LOSS.Low                                             |

## E.6.2.2 Communication of integrity relevant data protection strength level basic

The communication of integrity relevant data protection strength level basic shall protect against the following attack types:

**accidental bit flip:** Accidental change of data by natural causes.



# Internet Connected Toys (ICT) – Open issues

## Vertical specific open issues:

- Further refinement of requirements and assessments e.g. regarding parental control in relation to the age of children



# Q&A



# Personal Wearable Products





# Personal Wearable Products – Clause 1 (Scope)

## Technical Description Implementing Regulation (EU) 2025/2392 Annex I #19

- Personal wearable products to be worn or placed on a human body that have a health monitoring (such as tracking) purpose and to which Regulation (EU) 2017/745(2) or (EU) 2017/746 of the European Parliament and of the Council do not apply, or personal wearable products that are intended for the use by and for children:
  - “Personal wearable products to be worn or placed on a human body that have a health monitoring purpose are products with digital elements that are worn on the body directly or via clothing or accessories and that can, regularly or continuously, sense and further process information, including body metrics, relevant to the user’s health, excluding products that fall within the scope of Regulation (EU) 2017/745 or of Regulation (EU) 2017/746.
    - This category includes but is not limited to fitness trackers, smartwatches, smart jewellery, smart clothing and sports apparel that meet this description.”
  - “Personal wearable products that are intended for the use by and for children are products with digital elements which can be worn or placed on the body, directly or via clothing or accessories, of individuals under the age of 14.
    - This category includes but is not limited to child safety wearables..”

## Considerations

- Overlaps concerning parental control and geo-localization functionalities between personal wearable products that are intended for the use by and for children (falling under #19) and internet connected toys (falling under #18) .

# Personal Wearable Products – Examples of wearable products in scope



Smartwatches



Heart rate monitor belt



Fitness bands



Smart socks



Smartwatch with GPS tracking and Parental control



Complete baby monitoring system

## Considerations

- The category includes a broad range of products with different use cases and therefore different security profiles.
- The Implementing Regulation (EU) 2025/2392 talks about individual under the age of 14 years old. There is a clear separation between the product for babies under 2/3 years old, for which the monitoring is much more extensive but without the need of parental control, and the preadolescent child where GPS tracking and parental control are key functionalities and where the scenario seems to be an extension of the wearable for health monitoring.

# Personal Wearable Products – Clause 4 (Product Context)

Defined term (Clause 3) in the standard:

- sensor: device or component able to measure characteristics of its physical environment, generating data input representative of its physical environment
  - EXAMPLE: Blood pressure sensor, heart rate monitor, accelerometer, etc.
- controlled mobile operational environment: a mobile operational environment where the user is expected to be constantly carrying the product

Product functions (Clause 4) in the standard:

The present document addresses the following essential functionalities of products:

- Health monitoring functionalities
- Location-based functionalities

The essential and supporting functionalities might process the following data assets:

- health data;
- fitness data;
- input data from sensors;
- location data, including device location data;
- ...

# Personal Wearable Products – ANNEX D (Impact Classes)

Table 6: Mapping of specific data assets to impact classes

| specific function asset                             | impact class for function asset categories   |                                          |                                                     |
|-----------------------------------------------------|----------------------------------------------|------------------------------------------|-----------------------------------------------------|
|                                                     | impact class for integrity relevant function | impact class for time sensitive function | impact class for function, whose use can cause harm |
| Health monitoring functionalities                   | IMP.INT.High                                 | IMP.AVAL.TIME.High                       | IMP.FH.Medium                                       |
| Location-based functionalities                      | IMP.INT.Low                                  | IMP.AVAL.TIME.Medium                     | IMP.FH.Medium                                       |
| Notification functionalities                        | IMP.INT.Medium                               | IMP.AVAL.TIME.Medium                     | IMP.FH.Medium                                       |
| Input commands from user or other connected devices | IMP.INT.Low                                  | IMP.AVAL.TIME.Low                        | No                                                  |
| Data logging and storage                            | IMP.INT.Medium                               | IMP.AVAL.TIME.High                       | No                                                  |
| General functionalities                             | IMP.INT.Medium                               | IMP.AVAL.TIME.Medium                     | IMP.FH.Medium                                       |



# Personal Wearable Products – Open issues



Co-funded by  
the European Union



Vertical specific open issues:

- Alignment with EN 304 633 on the children definition and related requirements
- Further supporting functionalities (e.g. payment functionalities for high end smartwatch)
- Use case and Secure Profile definition

# Q&A



## Closing Remarks:

- Thank you for your interest in ETSI CRA IoT Standards
- Good standards need stakeholder feedback
- Feel encouraged to get in touch with us Rapporteurs when you have questions/need clarifications
- Use the commenting guidelines and commenting format you can find here <https://docbox.etsi.org/cyber/EUSR/Open> for providing formal feedback

### Commenting guidelines

Your comments to improve this interim draft are very welcomed. To ensure the effectiveness of your contribution, please make sure to include the following elements in your comment:

- 1) Clear identification of the section of the draft your comment is referring to.
- 2) Objective proposal to delete content, add content or substitute content.
- 3) Concrete contribution (exact content you suggest including in the draft as an addition to, or in substitution of, existing content).
- 4) Brief rationale to justify the proposal (e.g. why the suggested content should be added an/or the existing content should be deleted or substituted).

Please note that comments without concrete contributions will be noted but not acted upon by ETSI CYBER-EUSR. We trust and value your expertise and therefore expect you to take this opportunity to proactively contribute to solving the issues you find while analysing this interim draft.

|  The Standards People |                 |                |                             |                       |                              |                                          |                 |                                                    |
|-----------------------------------------------------------------------------------------------------------|-----------------|----------------|-----------------------------|-----------------------|------------------------------|------------------------------------------|-----------------|----------------------------------------------------|
| Product Vertical                                                                                          | Standard Number | Version Number | Author of comment           | Line number (e.g. 17) | Clause/ Subclause (e.g. 3.1) | Paragraph/ Figure/ Table/ (e.g. Table 1) | Type of comment | Concrete Proposal to Add, Change or Delete Content |
| Smart home assistants                                                                                     | EN 304 631      | v0.2.0         | Kilian Mitteregger, BSI GER |                       |                              |                                          | Editorial       |                                                    |
|                                                                                                           | #NV             |                |                             |                       |                              |                                          |                 |                                                    |



**Thank you for your attention**



Co-funded by  
the European Union

Follow us on:   